

Plataforma de Cursos Online

Stripe + Privacy by Design | Documentação Completa do Projeto

VERSÃO FINAL | Março 2026

Autor

Miguel Ribas Berlese

Projeto	Plataforma de Cursos Online — Stripe + Privacy by Design
Classificação	Confidencial
Versão	6.0 (Final — 3 análises críticas)
Conteúdo	9 partes integradas
Data	Março 2026

Sumário Geral

PARTE I	— Arquitetura da Plataforma v6.0 PDF-ARCH-001 24 seções, 11 tabelas, 3 análises críticas
PARTE II	— Validação do Problema e Solução PDF-PROB-001 Diagnóstico, público-alvo, diferencial competitivo
PARTE III	— Definição de Escopo e MVP PDF-SCOPE-001 O que entra e não entra, critérios de aceite
PARTE IV	— Levantamento de Requisitos PDF-REQ-001 20 RF, 10 RNF, 12 regras de negócio, restrições
PARTE V	— Público-Alvo e Personas PDF-PERS-001 3 personas, segmentação, matriz funcionalidades
PARTE VI	— Modelagem UX e Jornadas PDF-UX-001 11 casos de uso, jornada, 6 wireframes
PARTE VII	— Análise de Viabilidade PDF-VIAB-001 Técnica, financeira, operacional, Gantt
PARTE VIII	— Planejamento de Execução PDF-PLAN-001 Etapas, stack, equipe, marcos
PARTE IX	— Arquitetura de Ambientes PDF-ENV-001 DEV, Staging, Produção, bancos separados

PARTE I

Arquitetura da Plataforma v6.0

24 seções | 11 tabelas | 3 análises críticas | 0 lacunas

PDF-ARCH-001 v6.0

Sumário

- 01 Introdução
- 02 Problema do mercado
- 03 Princípios de arquitetura
- 04 Checkout sem cadastro
- 05 Modelo de identidade (user_token + apelido)
- 06 Integração Stripe
- 07 Pagamento como evento de acesso
- 08 Vinculação multi-sinal com resolução de conflitos
- 09 Renovação anual (Stripe Subscriptions)
- 10 Recuperação de acesso
- 11 Autenticação por PIN (com proteção anti-enumeração)
- 12 Matriz de permissões por auth_level
- 13 Fluxo completo do comprador
- 14 Estrutura do banco de dados
- 15 Anti-compartilhamento
- 16 Chargebacks é risk scoring
- 17 Política de reembolso configurável
- 18 Migração de compradores (com dados históricos)
- 19 Idempotência de webhooks
- 20 Backup é disaster recovery
- 21 Análise financeira completa
- 22 Riscos é mitigações
- 23 Roadmap é MVP
- 24 Conclusão

Este é o documento final de arquitetura (v6.0) de uma plataforma proprietária para cursos online de alto valor (R\$ 18.000/ano). Passou por três rodadas de análise crítica. A v4.0 corrigiu a premissa fundamental (pagamento não é identidade). A v5.0 adicionou renovação, migração, chargebacks, idempotência, device token é apelido. Esta v6.0 resolve as 8 últimas lacunas operacionais: conflito de sinais de vinculação, proteção contra enumeração de alias, UX do grace period, dados históricos pre-migração, risk scoring para chargebacks em série, política de reembolso configurável, backup/disaster recovery e matriz de permissões por nível de autenticação.

Com essas correções, o documento não possui lacunas arquiteturais conhecidas e está pronto para implementação.

Plataformas de mercado (Hotmart, Teachable) foram desenhadas para cursos de massa. Para cursos premium (R\$ 5.000 a R\$ 50.000/ano), três problemas emergem: **duplicação** (compradores usam e-mails diferentes — 200 compradores podem gerar 500 contas), **privacidade** (profissionais de alta renda preferem anonimato) é **compartilhamento** (10% de 200 compradores compartilhando = R\$ 360.000/ano perdidos). Raiz do problema: todas tratam e-mail como identidade.

Separacao identidade / pagamento / acesso

Identidade = user_token. Pagamento = evento. Acesso = enrollment. Tres conceitos distintos.

Privacy by Design

Dados pessoais nunca no banco da plataforma. Exclusivamente na Stripe. Banco comprometido = zero dados pessoais.

Anonimato opcional

Comprador decide quanto revelar. Minimo: user_token. Medio: apelido+PIN. Completo: e-mail.

Friccao mínima

Checkout sem cadastro via Stripe Checkout hospedado.

Seguranca progressiva

Tres níveis: token, apelido+PIN, e-mail+senha. Ações sensíveis exigem nível adequado (matriz de permissões v6.0).

Comprador clica comprar, é redirecionado para checkout.stripe.com, preenche dados na Stripe, é após confirmacao é redirecionado de volta com acesso provisionado. Backend cria Checkout Session via `stripe.checkout.sessions.create()`. Nenhum dado pessoal toca o servidor. Plataforma qualifica como SAQ-A (PCI compliance mais simples).

[!] **Princípio central:** Pagamento NÃO é identidade. É um evento que concede acesso. A identidade é o user_token gerado internamente.

Identidade = **user_token** (ex: USR_a7x9k2m4), gerado via `crypto.randomUUID()`. Propriedades: unicidade, estabilidade (nunca muda), opacidade (não revela info pessoal). O comprador pode definir um **apelido** memorável (ex: @trader42) para usar no login via PIN em vez do token completo.

Tres níveis de autenticação

Nível	Metodo	Seguranca	Recuperação
1. Token	access_token no URL	Mínima	Apenas se salvou o link
2. PIN	apelido + PIN 6 dígitos	Boa	Via token ou e-mail
3. Completo	E-mail + senha ou magic link	Máxima	Recuperação completa

Endpoints, webhooks é produtos

Endpoint / Evento	Tipo	Funcao
checkout.sessions.create	POST	Checkout hospedado
subscriptions.create	POST	Renovação anual
refunds.create	POST	Reembolso (com política configurável v6.0)
disputes.update	POST	Submeter evidência em chargeback
billingPortal.sessions.create	POST	Comprador atualiza pagamento (grace period v6.0)
checkout.session.completed	Webhook	Provisionamento (idempotente)
invoice.paid	Webhook	Renovação confirmada
invoice.payment_failed	Webhook	Falha renovação -> grace period + banner v6.0
charge.dispute.created	Webhook	Chargeback -> revogação + risk_score v6.0
charge.dispute.closed	Webhook	Resultado dispute -> atualiza risk_score v6.0
charge.refunded	Webhook	Revogacao por reembolso

Webhook `checkout.session.completed` dispara: (1) extrair dados seguros, (2) verificar idempotência em `stripe_events`, (3) executar vinculação multi-sinal com resolução de conflitos (v6.0), (4) registrar pagamento + criar enrollment, (5) preparar pos-compra com token + e-mail + PIN + apelido.

[i] Separacao clara: Um comprador = UMA identidade (`user_token`), MULTIPLOS pagamentos, cada pagamento = UM OU MAIS enrollments.

[!] **NOVO v6.0 — Resolução de conflitos:** A v5.0 listava 4 sinais mas não especificava o que acontece quando sinais apontam para compradores diferentes. A v6.0 implementa lógica de 3 estados: vincular automaticamente (sinais convergem), criar novo (nenhum match), ou sinalizar para revisao (sinais divergem).

Quatro sinais de vinculação

Sinal	Confiança	Quando vincula
1. stripe_customer_id	ALTA	Automático quando único match
2. E-mail da plataforma	ALTA	Automático quando match com e-mail verificado
3. card_fingerprint	MEDIA	Sugestao apenas (colisão possível)
4. Manual (access_token)	ALTA	Comprador vincula no painel

Lógica de 3 estados (NOVO v6.0)

Estado	Condicao	Acao do sistema
VINCULAR	Todos os sinais disponíveis convergem para o mesmo user_token, OU apenas 1 sinal disponível é de confiança alta	Vinculação automática. Pagamento associado ao user_token existente.
CRIAR NOVO	Nenhum sinal encontra match no banco	Novo user_token criado. Comprador genuinamente novo.
REVISAR	Dois ou mais sinais apontam para user_tokens DIFERENTES	Novo user_token criado com needs_review=true é merge_candidate_id preenchido. Painel admin exhibe para revisao. Comprador ve mensagem: 'Detectamos que você pode já ter conta. Deseja vincular?'

Essa lógica elimina o risco de vinculação errada irreversível. O estado REVISAR cria um caminho seguro para casos ambiguos, sem bloquear o acesso do comprador (ele recebe acesso imediato, é a vinculação com conta anterior pode ser feita depois).

1

Compra inicial

Stripe cria Subscription anual. Primeiro pagamento imediato.
`stripe.subscriptions.create`

2

30 dias antes

`invoice.upcoming`. Notificacao por e-mail (se cadastrou) é banner no painel.
Webhook + Resend

3

Data de renovação

Stripe cobra cartao salvo. `invoice.paid` -> enrollment renovado.
Stripe Billing

4

Falha no pagamento

`invoice.payment_failed` -> `grace_period` 7 dias. Banner persistente na area logada com countdown é link para billing portal (NOVO v6.0).
`billingPortal.sessions.create`

5

Expirado

Não pagou em 7 dias -> `expired`. Reativacao a qualquer momento pagando novamente.
`subscription.deleted`

[i] **NOVO v6.0 — Banner de grace period:** Quando enrollment entra em `grace_period`, banner aparece em TODAS as páginas da area logada: 'Seu pagamento não foi processado. Restam X dias para atualizar. [Atualizar pagamento]'. Link abre Stripe Billing Portal onde o comprador pode trocar cartao ou metodo. Banner desaparece automaticamente quando `invoice.paid` é recebido.

Status do enrollment

Status	Significado	Acesso
active	Pagamento em dia	LIBERADO
grace_period	Pagamento falhou, dentro dos 7 dias	LIBERADO (com banner)
expired	Não pagou após graça	BLOQUEADO
revoked	Reembolso ou chargeback	BLOQUEADO
cancelled	Cancelamento voluntário	BLOQUEADO ao fim do período
pending_review	Comprador high_risk (v6.0)	AGUARDANDO aprovação admin

Página pos-compra exibe: access_token com botao Copiar, campo e-mail opcional (recomendacao forte), opção PIN, opção apelido. Tres rotas de recuperação: apelido+PIN, magic link via e-mail, comprovante de pagamento (suporte localiza stripe_pi_id).

[i] Anonimato preservado: E-mail é para recuperação, não identificacao. Comprador pode usar e-mail descartavel. Nunca compartilhado com produtor.

PIN 6 dígitos + apelido memorável. Hash bcrypt armazenado (nunca o PIN). Rate limiting: 5 erros por apelido = bloqueio 30min. 15 erros = PIN inválido.

[!] NOVO v6.0 — Proteção anti-enumeração de alias: Endpoint de login NUNCA revela se o apelido existe. Resposta para alias inexistente é PIN errado é idêntica: 'Apelido ou PIN incorretos'. Tempo de resposta constante (bcrypt contra hash dummy quando alias não existe). Rate limiting POR IP: máximo 20 tentativas/hora independente do alias. Implementado via Redis com chave login_attempts:{ip} é TTL 1 hora.

[i] **NOVO v6.0:** A v5.0 criou o campo auth_level mas não especificou quais ações exigem qual nível. Sem essa especificação, qualquer sessão podia fazer qualquer coisa. A v6.0 define a matriz completa.

Matriz de permissões

Acao	token	pin	full
Assistir aulas	SIM	SIM	SIM
Ver progresso	SIM	SIM	SIM
Alterar apelido	NÃO	SIM	SIM
Vincular compras anteriores	NÃO	SIM	SIM
Gerenciar dispositivos	NÃO	SIM	SIM
Alterar e-mail	NÃO	NÃO	SIM
Alterar PIN	NÃO	NÃO	SIM
Solicitar reembolso	NÃO	NÃO	SIM
Excluir conta (LGPD)	NÃO	NÃO	SIM

Implementado como guard no NestJS que verifica auth_level da sessão antes de permitir a ação. Se insuficiente: 403 com mensagem indicando nível necessário é como alcançar.

FASE 1 — COMPRA

1

Página de vendas

Landing SSR. Nenhum cadastro.
Next.js

2

Stripe Checkout

Dados pessoais ficam na Stripe.
Checkout Session

3

Webhook

checkout.session.completed. Idempotente via stripe_events.
BullMQ

FASE 2 — PROVISIONAMENTO

4

Vinculação multi-sinal

4 sinais com lógica de 3 estados (vincular/criar/revisar v6.0).
Identity Service

5

Pagamento + enrollment

Dados seguros. Subscription anual. access_token.
Payment + Course Service

6

Pos-compra

Token + e-mail + PIN + apelido. Se high_risk: pending_review.
success_url

FASE 3 — ACESSO

7

Primeiro acesso

Device token em localStorage. Configura PIN/e-mail/apelido.
Device API

8

Conteúdo

Signed URLs temporárias. Progresso. Permissões por auth_level (v6.0).
Mux + Redis

9

Renovação

Automatica via Stripe. Banner de grace period se falhar (v6.0).
Subscriptions

10

Reembolso

Política configurável: janela + % progresso. Automático ou via admin (v6.0).

Refund Service

[i] Novidades v6.0: Campos needs_review + merge_candidate_id em users. risk_score em users. Tabelas risk_signals é legacy_payments. Campos refund_window_days + refund_max_progress em courses. Status pending_review em enrollments.

users

Identidade central. Sem dados pessoais. PIN + apelido + risk scoring.

Campo	Tipo	Restrição	Descrição
id	UUID	PK	gen_random_uuid()
user_token	VARCHAR(64)	UK, NOT NULL	Token publico
alias	VARCHAR(32)	UK, NULL	Apelido memoravel (@trader42)
display_name	VARCHAR(255)	NULL	Nome opcional
status	VARCHAR(20)	NOT NULL	active / suspended / blocked
total_spent	DECIMAL(12, 2)	DEFAULT 0	Acumulado BRL (payments + legacy_payments)
devices_limit	INTEGER	DEFAULT 2	Max devices
pin_hash	VARCHAR(72)	NULL	bcrypt hash do PIN
pin_attempts	INTEGER	DEFAULT 0	Tentativas incorretas
pin_locked_until	TIMESTAMPTZ	NULL	Bloqueio rate limit
risk_score	INTEGER	DEFAULT 0	Pontuacao de risco (v6.0). >100 = high_risk
needs_review	BOOLEAN	DEFAULT false	Sinais de vinculação divergentes (v6.0)
merge_candidate_id	UUID	FK -> users, NULL	Possivel duplicata para merge (v6.0)
created_at	TIMESTAMPTZ	NOT NULL	UTC
updated_at	TIMESTAMPTZ	NOT NULL	UTC

user_emails

E-mails opcionais para recuperação.

Campo	Tipo	Restrição	Descrição
id	UUID	PK	gen_random_uuid()
user_id	UUID	FK -> users	Comprador
email	VARCHAR(255)	NOT NULL	Endereço
is_primary	BOOLEAN	DEFAULT false	Principal

verified	BOOLEAN	DEFAULT false	Magic link
created_at	TIMESTAMPTZ	NOT NULL	UTC

payments			
Financeiro. Nenhum dado pessoal.			
Campo	Tipo	Restrição	Descrição
id	UUID	PK	gen_random_uuid()
user_id	UUID	FK -> users	Comprador
stripe_pi_id	VARCHAR(128)	UK, NOT NULL	PaymentIntent
stripe_cs_id	VARCHAR(128)	UK, NULL	Checkout Session
stripe_customer_id	VARCHAR(128)	IDX, NOT NULL	Customer Stripe
amount	DECIMAL(10,2)	NOT NULL	BRL
currency	VARCHAR(3)	DEFAULT 'brl'	Moeda
payment_method	VARCHAR(32)	NOT NULL	card/pix/boleto
card_last4	VARCHAR(4)	NULL	Últimos 4
card_brand	VARCHAR(32)	NULL	Bandeira
card_fingerprint	VARCHAR(128)	IDX, NULL	Hash secundário
status	VARCHAR(20)	NOT NULL	succeeded/pending/failed/refunded/disputed
paid_at	TIMESTAMPTZ	NULL	Confirmacao
created_at	TIMESTAMPTZ	NOT NULL	UTC

legacy_payments			
Histórico pre-migração — NOVO v6.0			
Campo	Tipo	Restrição	Descrição
id	UUID	PK	gen_random_uuid()
user_id	UUID	FK -> users	Comprador migrado
amount	DECIMAL(10,2)	NOT NULL	Valor BRL
payment_method	VARCHAR(64)	NULL	Descritivo: cartao, pix, transferencia
source	VARCHAR(64)	NOT NULL	hotmart / manual / transferencia
notes	TEXT	NULL	Observacoes
paid_at	TIMESTAMPTZ	NOT NULL	Data do pagamento original
created_at	TIMESTAMPTZ	NOT NULL	Data de importacao

stripe_events

Idempotência de webhooks.

Campo	Tipo	Restrição	Descrição
id	UUID	PK	gen_random_uuid()
stripe_event_id	VARCHAR(128)	UK, NOT NULL	evt_xxx
event_type	VARCHAR(64)	NOT NULL	Tipo do evento
processed	BOOLEAN	DEFAULT false	Processado com sucesso
created_at	TIMESTAMPTZ	NOT NULL	UTC

risk_signals

Histórico de eventos de risco — NOVO v6.0

Campo	Tipo	Restrição	Descrição
id	UUID	PK	gen_random_uuid()
user_id	UUID	FK -> users	Comprador
signal_type	VARCHAR(32)	NOT NULL	chargeback / dispute_lost / geo_anomaly / device_burst
score_delta	INTEGER	NOT NULL	+100 chargeback, +200 dispute_lost, +50 geo_anomaly
description	TEXT	NULL	Detalhes do evento
created_at	TIMESTAMPTZ	NOT NULL	UTC

courses

Catálogo. Agora com política de reembolso configurável.

Campo	Tipo	Restrição	Descrição
id	UUID	PK	gen_random_uuid()
slug	VARCHAR(128)	UK, NOT NULL	URL-friendly
title	VARCHAR(255)	NOT NULL	Título
price	DECIMAL(10,2)	NOT NULL	BRL
stripe_price_id	VARCHAR(128)	NULL	price_xxx
stripe_product_id	VARCHAR(128)	NULL	prod_xxx
refund_window_days	INTEGER	DEFAULT 7	Dias para reembolso automático (v6.0)
refund_max_progress	INTEGER	DEFAULT 20	% max progresso para elegibilidade (v6.0)
refund_requires_approval	BOOLEAN	DEFAULT false	Se requer aprovação admin (v6.0)

status	VARCHAR(20)	NOT NULL	active/draft/archived
created_at	TIMESTAMPTZ	NOT NULL	UTC

enrollments

Acesso com subscription + grace period + review.

Campo	Tipo	Restrição	Descrição
id	UUID	PK	gen_random_uuid()
user_id	UUID	FK -> users	Comprador
course_id	UUID	FK -> courses	Curso
payment_id	UUID	FK -> payments	Pagamento
access_token	VARCHAR(64)	UK, NOT NULL	Token
stripe_subscription_id	VARCHAR(128)	IDX, NULL	sub_xxx
status	VARCHAR(20)	NOT NULL	active/grace_period/expired/revoked/cancelled/pending_review
grace_period_until	TIMESTAMPTZ	NULL	Fim do grace period
expires_at	TIMESTAMPTZ	NULL	Expiração período pago
needs_review	BOOLEAN	DEFAULT false	Vinculação ambigua (v6.0)
created_at	TIMESTAMPTZ	NOT NULL	UTC

devices

Anti-compartilhamento. Device token primário.

Campo	Tipo	Restrição	Descrição
id	UUID	PK	gen_random_uuid()
user_id	UUID	FK -> users	Comprador
device_token	VARCHAR(128)	UK, NOT NULL	Token aleatorio localStorage
ua_fingerprint	VARCHAR(128)	IDX, NULL	Backup
device_name	VARCHAR(255)	NULL	Chrome - Windows
is_trusted	BOOLEAN	DEFAULT true	Autorizado
last_ip	INET	NULL	Último IP
first_seen_at	TIMESTAMPTZ	NOT NULL	Primeiro
last_seen_at	TIMESTAMPTZ	NOT NULL	Último

sessions			
Sessoes com auth_level funcional.			
Campo	Tipo	Restrição	Descrição
id	UUID	PK	gen_random_uuid()
user_id	UUID	FK -> users	Comprador
device_id	UUID	FK -> devices	Device
session_token	VARCHAR(128)	UK, NOT NULL	JWT
ip_address	INET	NOT NULL	IP
auth_level	VARCHAR(10)	NOT NULL	token/pin/full — determina permissões (v6.0)
is_active	BOOLEAN	DEFAULT true	Ativa
expires_at	TIMESTAMPTZ	NOT NULL	Expiração
created_at	TIMESTAMPTZ	NOT NULL	UTC

Tabela lessons permanece conforme v4.0+. Total: 11 tabelas (9 originais + stripe_events v5.0 + legacy_payments v6.0 + risk_signals v6.0).

Device token + limite

Token aleatorio localStorage. 2-3 devices. Mais estável que UA fingerprint.

Sessão única concorrente

Max 1 ativa. Anterior encerrada (Netflix).

PIN como barreira

Apelido + PIN exige confiança para compartilhar.

Marca d'agua invisível

user_token nos videos (pos-lançamento).

Análise comportamental + risk scoring

IPs anômalos -> risk_signal registrado -> risk_score atualizado (v6.0).

Fluxo de chargeback com risk scoring (v6.0)

- 1 charge.dispute.created**
Stripe notifica chargeback.
Webhook
- 2 Revogacao imediata**
Enrollment -> revoked. Acesso bloqueado.
UPDATE enrollments
- 3 Risk score +100**
risk_signals registrado. risk_score do user atualizado. Se >100: high_risk.
INSERT risk_signals
- 4 Coleta de evidência**
Logs de acesso, progresso, devices — automática.
Evidence collector
- 5 Submissao a Stripe**
Evidencia via disputes.update.
Stripe Disputes API
- 6 Resultado (charge.dispute.closed)**
Ganhou: risk_score -50, enrollment pode reativar. Perdeu: risk_score +200, user marcado high_risk.
Webhook handler
- 7 Proxima compra de user high_risk**
Enrollment criado como pending_review. Admin precisa aprovar antes de liberar acesso.
Auth guard

[i] **NOVO v6.0:** Sem política clara, cada pedido de reembolso vira decisao manual. A v6.0 implementa regras configuráveis por curso.

Tres parametros por curso

Parametro	Default	Descrição
refund_window_days	7 dias	Dias após compra em que reembolso é automático
refund_max_progress	20%	Progresso máximo no curso para elegibilidade
refund_requires_approval	false	Se pedidos fora dos criterios vao para fila admin

Fluxo: Comprador solicita reembolso no painel (requer auth_level=full). Se dentro de refund_window_days E progresso menor que refund_max_progress: reembolso automático via stripe.refunds.create(), enrollment -> revoked. Se fora dos criterios é refund_requires_approval=true: pedido vai para fila admin. Se refund_requires_approval=false: reembolso negado com explicacao.

1

Gerar claim codes

Código único 8 chars por comprador existente (MIGR-XXXXXXX).

Script

2

Importar histórico

Pagamentos anteriores na tabela legacy_payments (v6.0). total_spent calculado como payments + legacy.

SQL import

3

Enviar comunicacao

E-mail/mensagem com claim code + link.

Resend

4

Comprador reivindica

Informa claim code. user_token + enrollment criados. Sem novo pagamento.

Claim endpoint

5

Configura acesso

Apelido + PIN + e-mail (tudo opcional).

Onboarding

6

Prazo 90 dias

Claims expiram. Apos prazo: suporte manual.

TTL

[i] **NOVO v6.0 — Dados históricos:** Tabela legacy_payments preserva todo o histórico financeiro pre-migração. Campo total_spent em users é calculado como SUM(payments.amount) + SUM(legacy_payments.amount), garantindo visao de LTV completa desde o primeiro pagamento.

Tabela stripe_events com stripe_event_id (UK). Antes de processar: verificar se evt_xxx existe. Se existe é processed=true: retornar 200 sem fazer nada. Se existe é processed=false: reprocessar. Se não existe: inserir é processar. Toda operação de provisionamento em transação PostgreSQL (BEGIN...COMMIT/ROLLBACK).

[i] **NOVO v6.0:** Nenhuma versão anterior especificava backup. Como a plataforma não armazena dados pessoais, a perda do banco significa perda irreversível de todos os `user_tokens` e `enrollments` — sem como identificar os compradores.

Tres camadas de backup

Camada	Metodo	Retencao	RPO
1. Contínuo	WAL archiving (PostgreSQL)	7 dias	5 minutos
2. Diário	Snapshot completo -> S3	30 dias	24 horas
3. Semanal	Snapshot -> S3 (versionado)	1 ano	7 dias

Objetivos: RTO (Recovery Time Objective) = 1 hora. RPO (Recovery Point Objective) = 5 minutos. No MVP com Railway: backups automáticos diários nativos. Na escala com AWS RDS: todas as 3 camadas configuráveis. Redis: snapshotting a cada 5 min + AOF persistence.

Receita por cenário

Cenário	Compradores	Receita	Stripe PIX	Líquido
Conservador	100	R\$ 1.800.000	R\$ 21.420	R\$ 1.778.580
Moderado	300	R\$ 5.400.000	R\$ 64.260	R\$ 5.335.740
Otimista	500	R\$ 9.000.000	R\$ 107.100	R\$ 8.892.900

Custos operacionais mensais

Item	100 comp.	300 comp.	500 comp.
Hospedagem	R\$ 500	R\$ 1.200	R\$ 2.500
Video (Mux/Bunny)	R\$ 800	R\$ 2.000	R\$ 4.000
PostgreSQL managed	R\$ 200	R\$ 500	R\$ 1.000
Redis managed	R\$ 100	R\$ 200	R\$ 400
E-mail (Resend)	R\$ 50	R\$ 100	R\$ 200
Backup S3 (v6.0)	R\$ 50	R\$ 100	R\$ 200
Dominio + CDN	R\$ 100	R\$ 100	R\$ 200
TOTAL MENSAL	R\$ 1.800	R\$ 4.200	R\$ 8.500
% da receita	1,2%	0,9%	1,1%

ROI

Métrica	Valor
Receita perdida por compartilhamento/ano	R\$ 360.000
Custo MVP (desenvolvimento)	R\$ 40.000 - 60.000
Custo operacional ano 1	~R\$ 30.000
Investimento total ano 1	~R\$ 90.000
Payback	Menos de 3 meses (conservador)

Risco 1: Recuperação de acesso

Comprador perdeu token, PIN e não cadastrou e-mail.

Mitigação: Três rotas: apelido+PIN, magic link, comprovante. Pós-compra recomenda fortemente.

Risco 2: Limitação stripe_customer_id

E-mails diferentes na Stripe = Customer IDs diferentes.

Mitigação: 4 sinais + lógica de 3 estados (v6.0). Nunca vincula automaticamente com conflito.

Risco 3: Chargeback fraudulento em série

Comprador faz chargeback, compra de novo, faz chargeback de novo.

Mitigação: risk_score acumulativo (v6.0). >100 = high_risk -> pending_review em próximas compras.

Risco 4: LGPD

Fingerprints, IPs, device tokens são dados pessoais.

Mitigação: Privacy policy. Exclusão. Hashes irreversíveis. DPO.

Risco 5: Enumeração de alias

Atacante descobre quais alias existem testando login.

Mitigação: Resposta idêntica para alias inexistente e PIN errado. Rate limit por IP: 20/hora (v6.0).

Risco 6: Falha na renovação

Cartão expirado.

Mitigação: Smart retries Stripe + grace period 7 dias + banner persistente com link billing portal (v6.0).

Risco 7: Reembolso abusivo

Comprador assiste tudo e pede reembolso.

Mitigação: Política configurável: refund_window_days + refund_max_progress (v6.0). Reembolso negado se progresso > limite.

Risco 8: Perda do banco de dados

Falha catastrófica sem backup.

Mitigação: 3 camadas de backup: WAL contínuo (RPO 5min) + snapshot diário + semanal. RTO 1h (v6.0).

Fase 1 — MVP (meses 1-3)

Lançamento (~12 sem): Landing, Checkout, vinculação 4 sinais com 3 estados, apelido+PIN (anti-enumeração), e-mail opcional, player, device token, sessao unica, permissões por auth_level, migração com claim codes + legacy_payments, idempotência, backup, painel admin.

Pos-lançamento (~4 sem): Subscriptions + grace period banner, chargebacks + risk scoring, política reembolso, marca d'agua, análise comportamental.

Fase 2 — Multi-tenant (meses 4-8)

Entregas: Isolamento tenant, Stripe Connect, branding, analytics, RLS, chargeback handling cross-tenant.

KPI: 10+ produtores, churn < 5%.

Fase 3 — Plataforma (meses 9-15)

Entregas: API publica, plugins, white-label, certificados. Comissao 3-5% + assinatura.

KPI: 100+ produtores, GMV > R\$1M/mes.

[\$] Investimento total: MVP lançamento R\$ 40-60 mil + pos-lançamento R\$ 15-20 mil + operacional ano 1 R\$ 30 mil = ~R\$ 100 mil total. Equivale a 5-6 compradores. Payback conservador: 3 meses.

A versão 6.0 é a versão final deste documento. Passou por 3 rodadas de análise crítica e não possui lacunas arquiteturais conhecidas.

Evolução completa

Versão	Premissa corrigida	Adições principais
v1-v3	Pagamento = identidade (ERRADO)	Conceito inicial, Pagar.me, privacy proxy
v4.0	user_token = identidade (CORRETO)	PIN, e-mail opcional, stripe_customer_id
v5.0	stripe_customer_id falível	Renovação, migração, chargebacks, idempotência, apelido, device token
v6.0	Lacunas operacionais	Conflito de sinais, anti-enumeração, risk scoring, reembolso configurável, backup, permissões, legacy_payments

O sistema agora cobre o ciclo de vida completo do comprador: checkout sem cadastro, vinculação multi-sinal com resolução de conflitos, autenticação progressiva com proteção anti-enumeração, renovação anual com grace period é banner, reembolso configurável, chargebacks com risk scoring preventivo, migração de base existente com dados históricos, idempotência total de webhooks, matriz de permissões por nível de autenticação, é backup com RPO de 5 minutos.

O documento contém 24 seções, 11 tabelas de banco de dados (com todos os campos, tipos, restrições e descrições), e está preparado para receber o banco de dados real para complementação final.

Controle de versão final

PDF_ID: PDF-ARCH-001 | Versão: 6.0 (FINAL)

Análises críticas: 3 rodadas | Lacunas conhecidas: 0

Tabelas no banco: 11 | Seções: 24

Este documento é a versão canônica e definitiva. Todas as versões anteriores (v1-v5) devem ser descartadas.

Ao receber o banco de dados real, o esquema será complementado com mapeamento, migrações SQL e ERD atualizado.

Desenvolvimento

Homologação

Produção

Bancos de dados por ambiente

PARTE 9 — Arquitetura da Plataforma (v6.0) (PDF-ARCH-001)

24 seções

11 tabelas de banco de dados

3 análises críticas

Zero lacunas conhecidas

PARTE I

Validação do Problema e Solução

Análise de mercado, diferencial competitivo e proposta de valor

PDF-PROB-001

Ticket médio
R\$ 18k/ano
por comprador

Perda estimada
R\$ 360k/ano
por compartilhamento

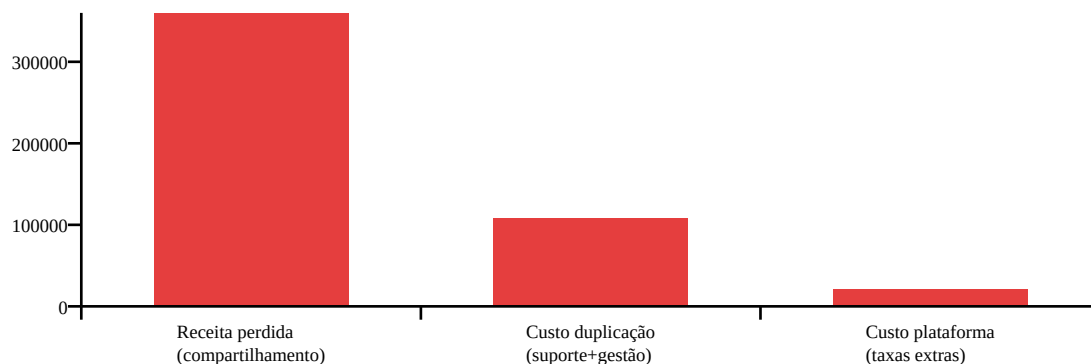
Base típica
200-500
compradores ativos

ROI estimado
300%+
no primeiro ano

01 Diagnóstico do problema

Produtores de cursos online de alto valor (R\$ 5.000 a R\$ 50.000/ano) enfrentam três problemas simultâneos que as plataformas de mercado não resolvem. A **duplicação massiva de contas** ocorre porque compradores usam e-mails diferentes a cada compra, gerando uma base inflada onde 200 compradores reais aparecem como 500 contas. A **ausência de anonimato** impede que profissionais de alta renda adquiram cursos sobre temas sensíveis sem expor sua identidade. O **compartilhamento de acesso**, incentivado pelo alto ticket, representa perda financeira mensurável.

Impacto financeiro anual (base 200 compradores)



R

Ricardo A.

42 anos | Trader e educador

Renda: R\$ 120k/mês

"Sei que tem gente usando login de amigo."

M

Mariana S.

35 anos | Advogada

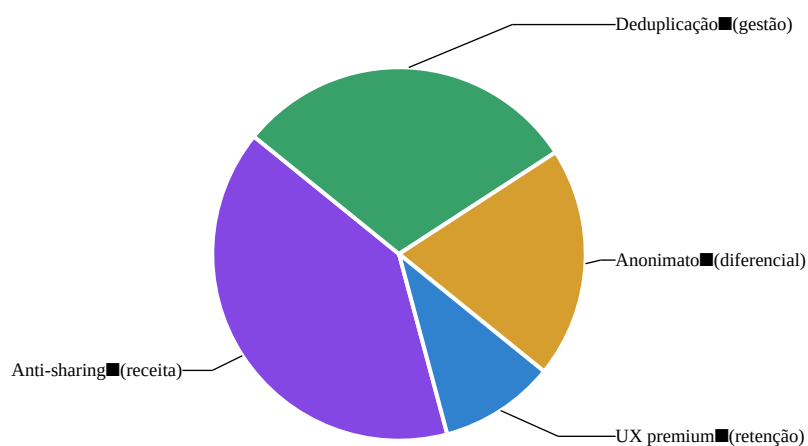
Renda: R\$ 45k/mês

"Paguei R\$ 18 mil e não consigo acessar."

Segmento primário: **produtor de cursos premium** — especialista em nicho de alto valor, 50 a 1.000 compradores, R\$ 500 mil a R\$ 10 milhões/ano. Segmento secundário: **comprador de alto valor** — profissional com renda elevada que valoriza discrição e praticidade.

Capacidade	Hotmart	Teachable	Nossa plataforma
Checkout sem cadastro	Não	Não	Sim
Anonimato do comprador	Não	Não	Nativo
Privacy by Design	Não	Não	Sim
Anti-compartilhamento	Básico	Básico	5 camadas
Deduplicação inteligente	Não	Não	4 sinais
Autenticação sem e-mail	Não	Não	Apelido + PIN

Composição da proposta de valor

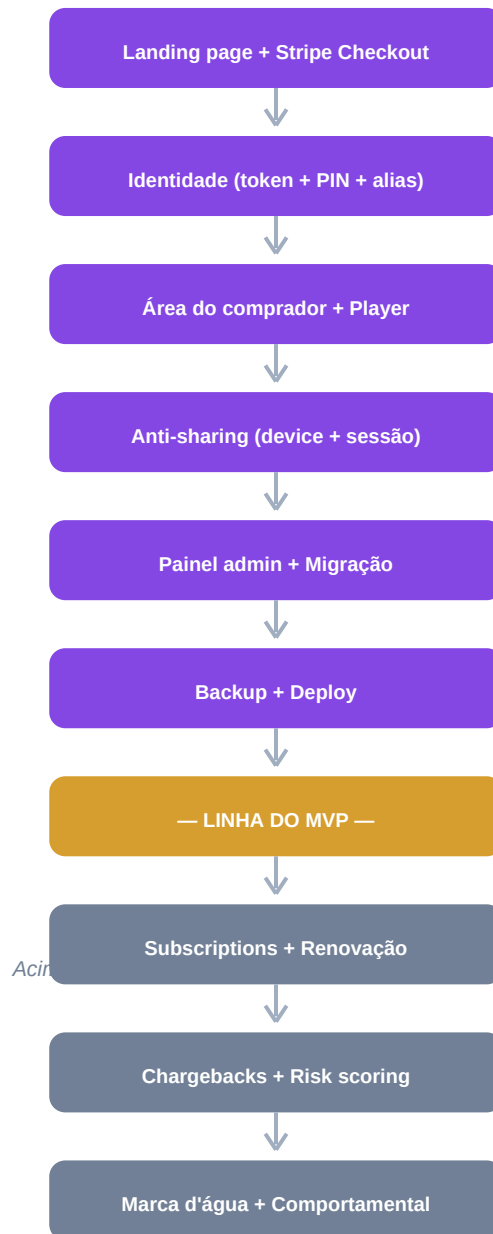


PARTE II

Definição de Escopo e MVP

Delimitação, prioridades e critérios de aceitação

PDF-SCOPE-001



Módulo	Funcionalidade	Critério de aceite
Landing	Página de vendas SSR + CTA Stripe	Carrega < 2s, responsiva
Checkout	Stripe Session, PIX + cartão, webhook idempotente	Pagamento processado, token entregue
Identidade	user_token, 4 sinais + 3 estados, alias, PIN + bcrypt	Deduplicação funciona, PIN valida
Recuperação	E-mail opcional, magic link	Magic link funciona
Área comprador	Player, progresso, permissões auth_level	Vídeo reproduz, progresso salva
Anti-sharing	Device token limit (2), sessão única	3º device bloqueado
Admin	Compradores, status, devices, receita	Admin gerencia e filtra
Migração	Claim codes + legacy_payments	Migrado acessa, histórico ok
Backup	WAL + snapshot diário	Restore testado, RPO 5min

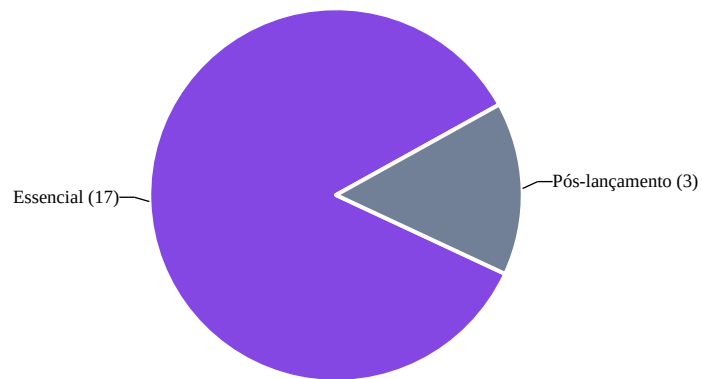
PARTE III

Levantamento de Requisitos

Funcionais, não-funcionais, regras de negócio, restrições e perfis

PDF-REQ-001

Distribuição de requisitos funcionais



01 Requisitos funcionais

ID	Requisito	Prioridade
RF01	Compra via Stripe Checkout sem cadastro prévio	Essencial
RF02	Gerar user_token único	Essencial
RF03	Apelido memorável opcional	Essencial
RF04	PIN 6 dígitos com bcrypt	Essencial
RF05	E-mail opcional para recuperação	Essencial
RF06	Vincular via 4 sinais + 3 estados	Essencial
RF07	Limitar 2 dispositivos	Essencial
RF08	1 sessão ativa por vez	Essencial
RF09	Signed URLs temporárias	Essencial
RF10	Progresso automático	Essencial
RF11	Webhooks idempotentes	Essencial
RF12	Painel admin	Essencial
RF13	Migração via claim codes	Essencial
RF14	Magic link	Essencial
RF15	Rate limit PIN: 5 erros = 30min	Essencial
RF16	Rate limit IP: 20/hora	Essencial
RF17	Permissões por auth_level	Essencial
RF18	Stripe Subscriptions	Pós-lanc.
RF19	Chargebacks + risk_score	Pós-lanc.
RF20	Reembolso configurável	Pós-lanc.

RN01

Identidade = user_token, não e-mail.

RN02

Pagamento = evento de acesso, não identidade.

RN03

4 sinais de vinculação. Divergência = needs_review.

RN04

Máximo 2 devices simultâneos.

RN05

1 sessão ativa. Nova encerra anterior.

RN06

PIN: 5 erros = bloqueio 30min, 15 = invalidado.

RN07

Rate limit IP: 20 tentativas/hora.

RN08

Ações sensíveis exigem auth_level=full.

RN09

Dados pessoais NUNCA no banco da plataforma.

RN10

Resposta idêntica para alias inexistente e PIN errado.

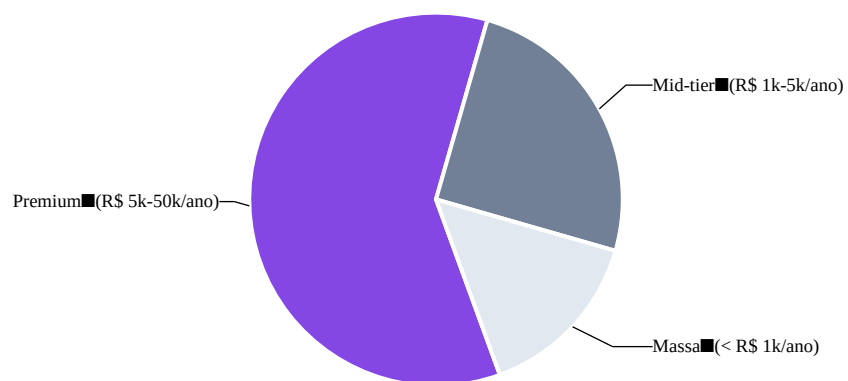
PARTE IV

Público-Alvo e Personas

Perfis detalhados dos usuários da plataforma

PDF-PERS-001

Segmentação de mercado (foco: premium)



01

Persona 1: Ricardo (produtor)



Ricardo Almeida

42 anos | Trader e educador

Renda: R\$ 120k/mês

"Sei que tem gente usando login de amigo pra acessar."

Curso: Mentoria Day Trading — R\$ 18.000/ano

Compradores: 230 (base mostra 580 contas)

Faturamento: ~R\$ 4,1 milhões/ano

Dor principal: Não sabe quantos clientes reais tem. Estima 10-15% compartilham.

**Mariana Souza**

35 anos | Advogada tributarista

Renda: R\$ 45k/mês

"Paguei R\$ 18 mil e não consigo acessar."

Contexto: Comprou curso de trading. Não quer que colegas saibam.

Comportamento: E-mail descartável. 2 contas sem saber.

Dor principal: Perdeu acesso. Suporte pediu CPF e ela recusou.

**Carlos Mendes**

48 anos | Médico cirurgião

Renda: R\$ 80k/mês

*"Meu tempo vale R\$ 500/hora. Não quero gastar 10 min resetando senha."***Contexto:** Curso de gestão de clínicas. Acessa entre cirurgias.**Dispositivos:** Celular, tablet, computador do consultório.**Dor principal:** Plataforma exige login e-mail+senha. Esquece, perde 10 minutos.**Matriz personas × funcionalidades**

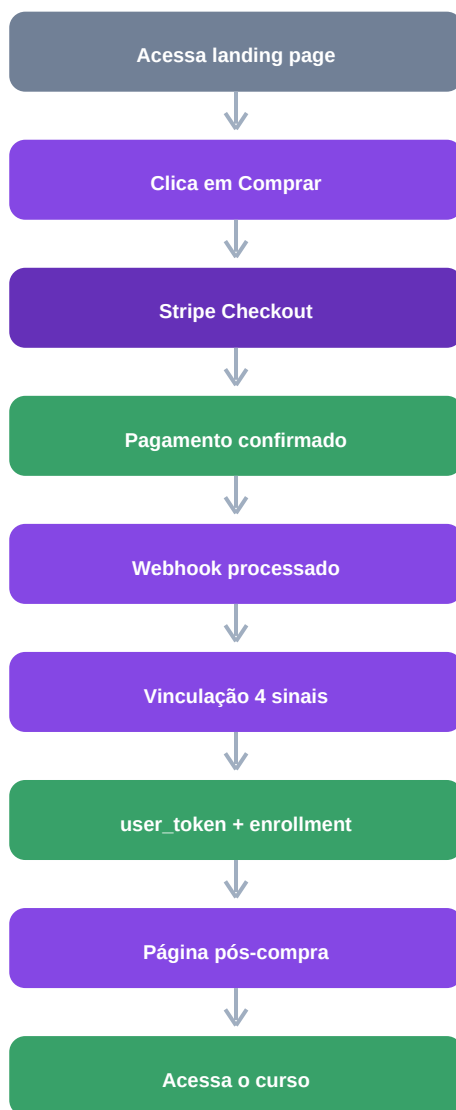
Funcionalidade	Ricardo	Mariana	Carlos
Checkout sem cadastro	Reduz abandono	Essencial	Essencial
Anonimato	Diferencial venda	Essencial	Indiferente
Anti-compartilhamento	Essencial	Indiferente	Indiferente
PIN + apelido	Facilita suporte	Bom	Essencial
Deduplicação	Essencial	Resolve 2 contas	Indiferente

PARTE V

Modelagem UX e Jornadas

Casos de uso, jornadas, fluxos e wireframes

PDF-UX-001



02	Jornada do comprador
1	Descobre o curso Anúncio, indicação ou conteúdo. Marketing
2	Página de vendas Descrição, depoimentos. Decide comprar. Landing SSR
3	Checkout Stripe Redirecionado. Nenhum cadastro. checkout.stripe.com
4	Pagamento processado Webhook dispara provisionamento. Idempotente
5	Página pós-compra Token, e-mail, PIN, apelido. success_url
6	Primeiro acesso Device registrado. Conteúdo disponível. Signed URL
7	Configura acesso Apelido + PIN (opcional). Painel
8	Acessos seguintes Apelido + PIN. 5 segundos. Login PIN

Landing page

Título do Curso

Descrição...

Depoimentos

COMPRAR AGORA

Pós-compra

Compra confirmada!

USR_a7x9k2m4 [Copiar]

E-mail (opcional)

PIN (6 dígitos)

Apelido (@...)

ACESSAR CURSO

Login via PIN

Acessar curso

Apelido (@trader42)

PIN (6 dígitos)

ENTRAR

Esqueci meu acesso

Painel admin

Compradores (230)

Buscar...

USR_a7x @trader42 active R\$36k

USR_b3m @maria.p active R\$18k

EXPORTAR

PARTE VI

Análise de Viabilidade

Técnica, financeira, operacional e de prazo

PDF-VIAB-001

Investimento
R\$ 90k
ano 1 total

Payback
3 meses
conservador

ROI
300%+
ano 1

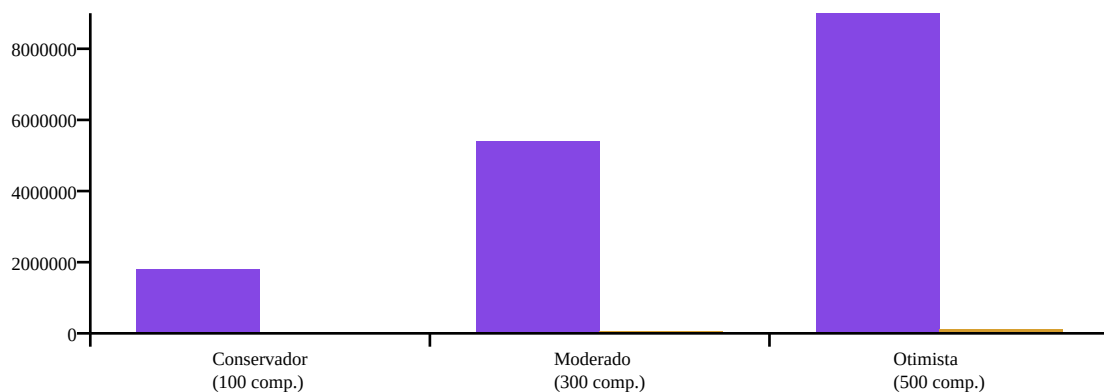
Custo/receita
~1%
operacional

01 Viabilidade técnica

Stack composta por tecnologias maduras (Next.js, NestJS, PostgreSQL, Redis, Stripe). Nenhum componente experimental. Complexidade moderada. 12 semanas com 1-2 devs TypeScript experientes é realista.

02 Viabilidade financeira

Receita vs. taxas Stripe por cenário



Item	Valor
Desenvolvimento MVP	R\$ 40.000 a R\$ 60.000
Operacional ano 1	~R\$ 30.000
Investimento total	~R\$ 90.000
Receita recuperável	R\$ 360.000/ano
Payback	3 meses

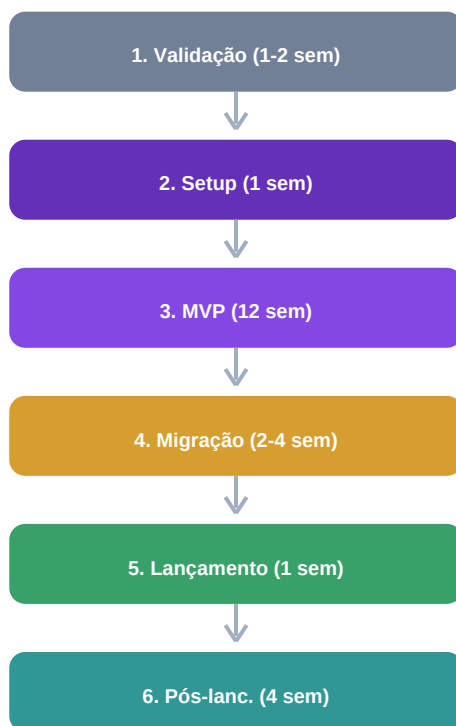


PARTE VII

Planejamento de Execução

Etapas, stack, equipe e marcos

PDF-PLAN-001



02

Stack e equipe

Camada	Tecnologia
Frontend	Next.js 14+ / TypeScript / Tailwind CSS
Backend	NestJS / TypeScript
Banco	PostgreSQL 16+ / Redis 7+
Pagamentos	Stripe (Checkout + Subscriptions + Disputes)
Vídeo	Mux ou Bunny Stream
Hospedagem	Vercel + Railway

03

Marcos principais

Marco	Semana	Entregável	Critério de aceite
M1	2	Checkout funcional	Pagamento processado, token entregue
M2	5	Identidade completa	4 sinais + PIN + alias testados
M3	8	Área do comprador	Vídeo, progresso, auth_level
M4	11	Admin + migração	Painel e claim codes funcionais
M5	12	Go-live	Em produção, backup testado

PARTE VIII

Arquitetura de Ambientes

Desenvolvimento, homologação e produção

PDF-ENV-001

Característica	Desenvolvimento	Homologação	Produção
Propósito	Construir e experimentar	Testar e validar	Entregar ao usuário
Dados	Fictícios (seed)	Amostra anonimizada	Dados reais
Estabilidade	Instável (normal)	Estável (simulada)	Máxima
Deploy	Contínuo (CI/CD)	Controlado (sprint)	Rigorous (blue/green)
Banco	app_dev (local)	app_staging (dedicado)	app_production (RDS)
Stripe key	sk_test_xxx	sk_test_xxx	sk_live_xxx
Backup	Não necessário	Diário	Contínuo + point-in-time
Acesso	Desenvolvedores	QA + stakeholders	Compradores reais

[i] Regra de ouro: Nunca teste em produção. Cada ambiente tem seu próprio banco de dados, suas próprias variáveis de ambiente e suas próprias chaves da Stripe. O documento completo (PDF-ENV-001) detalha cada ambiente com exemplos práticos e checklist de implementação.

PARTE IX

Arquitetura da Plataforma

Documento principal — PDF-ARCH-001 v6.0 (24 seções, 11 tabelas)

PDF-ARCH-001 v6.0

O PDF-ARCH-001 v6.0 é o documento principal do projeto, com 24 seções e 11 tabelas de banco de dados. Passou por 3 rodadas de análise crítica e não possui lacunas arquiteturais conhecidas. Esta seção apresenta um resumo dos conceitos centrais. Para especificação completa, consultar o PDF-ARCH-001 v6.0 na íntegra.

Evolução da arquitetura

Versão	Premissa corrigida	Adições
v1-v3	Pagamento = identidade (errado)	Conceito inicial
v4.0	user_token = identidade (correto)	PIN, e-mail opcional, stripe_customer_id
v5.0	stripe_customer_id falível	Renovação, migração, chargebacks, apelido
v6.0	Lacunas operacionais	Conflito sinais, risk scoring, reembolso, backup, permissões

Conceitos centrais

Identidade = user_token

Gerado internamente, estável, independente do pagamento. Não derivado de e-mail ou dado pessoal.

Pagamento = evento de acesso

Concede enrollment, não define identidade. Vinculado via 4 sinais com lógica de 3 estados.

Privacy by Design

Zero dados pessoais no banco. CPF, telefone, endereço ficam na Stripe. Banco comprometido = zero vazamento.

Autenticação progressiva

3 níveis: token (mínimo), apelido+PIN (intermediário), e-mail (completo). Matriz de permissões por nível.

Anti-compartilhamento

5 camadas: device token, sessão única, PIN, marca d'água, análise comportamental.

Tabelas do banco de dados (11)

Tabela	Descrição	Campos-chave
users	Identidade central, sem dados pessoais	user_token, alias, pin_hash, risk_score
user_emails	E-mails opcionais	email, verified
payments	Financeiro (sem CPF/tel)	stripe_pi_id, stripe_customer_id, card_last4
legacy_payments	Histórico pré-migração	amount, source, paid_at
stripe_events	Idempotência de webhooks	stripe_event_id, processed
risk_signals	Histórico de riscos	signal_type, score_delta
courses	Catálogo com política reembolso	refund_window_days, refund_max_progress
enrollments	Acesso com subscription	access_token, stripe_subscription_id, status

devices	Anti-compartilhamento	device_token, is_trusted
sessions	Sessões com auth_level	auth_level, is_active
lessons	Aulas individuais	video_external_id, sort_order

[i] Documento completo: Para especificações detalhadas de cada tabela (todos os campos, tipos, restrições e descrições), fluxos de renovação, chargebacks, migração e todas as 24 seções, consultar o PDF-ARCH-001 v6.0 na íntegra.

Fim do documento

Autor: Miguel Ribas Berlese

Projeto: Plataforma de Cursos Online — Stripe + Privacy by Design

Versão: 6.0 (Final) | 9 documentos integrados | 3 análises críticas | 0 lacunas

Classificação: Confidencial

Data: Março 2026

Este documento consolida toda a documentação do projeto em um único arquivo.
Para especificações completas de cada área, consultar os PDFs individuais por PDF_ID.